

DOCUMENTAÇÃO TÉCNICA E FUNCIONAL

KIDSPRO

Sistema de Gestão e PDV para Lojas | SaaS multi-loja

- Painel Master de licenças
- PDV Desktop: caixa, estoque, clientes e relatórios
- PDV Mobile: venda rápida com leitor de código

Versão do documento: 2.0

Data: 30/09/2026

Base: código-fonte v2.0 (admin, index, app) e kidspro_setup.sql

Sumário

1. Visão geral	2
1.1 Objetivo deste documento	2
1.2 O que é o KidsPro	2
1.3 Principais recursos	2
1.4 Componentes da solução	3
2. Arquitetura	3
2.1 Visão geral	3
2.2 Stack tecnológica	4
2.3 Modelo multi-loja (multi-tenant)	4
2.4 Sessão e licenciamento	4
2.5 Chaves de armazenamento local	5
2.6 Camada de segurança no banco	5
3. Módulos do sistema	6
3.1 Painel Master (admin.html)	6
3.2 PDV Desktop (index.html)	6
3.3 PDV Mobile (app.html)	7
4. Modelo de dados	8
4.1 Tabelas	8
4.2 Estruturas JSON	10
4.3 Funções SQL	10
5. Regras de negócio	11
6. Fluxos operacionais	12
6.1 Login e validação de licença	12
6.2 Venda no PDV desktop	12
6.3 Venda no PDV mobile	12
6.4 Devolução ou troca	12
6.5 Recebimento de fiado	12
6.6 Cadastro de produto	13
7. Guias rápidos por perfil	13
7.1 Administrador da plataforma	13
7.2 Lojista / operador de caixa (desktop)	13
7.3 Vendedor (mobile)	13
8. Guia de implantação	14
8.1 Pré-requisitos	14
8.2 Instalação nova	14
8.3 Atualização a partir da versão 1.0	14
8.4 O que o script SQL faz	14

8.5 Checklist de validação pós-implantação	15
9. Segurança	15
9.1 Controles implementados	15
9.2 Pontos que ainda merecem atenção	16
9.3 Como verificar o isolamento	16
10. Histórico de alterações (v1.0 para v2.0)	17
11. Limitações conhecidas	18
12. Melhorias recomendadas	18
Prioridade alta	18
Prioridade média	18
Prioridade baixa	18
13. Referência de funções	19
13.1 Funções JavaScript	19
13.2 Funções SQL	20
14. Glossário	20

1. Visão geral

1.1 Objetivo deste documento

Este documento descreve a arquitetura, as funcionalidades, o modelo de dados, as regras de negócio, os procedimentos de operação e de implantação do sistema **KidsPro**, além do modelo de segurança, do histórico de alterações e das melhorias recomendadas. Esta é a **versão 2.0**, elaborada a partir do código-fonte atualizado dos três arquivos HTML e do script kidspro_setup.sql.

1.2 O que é o KidsPro

O KidsPro é um sistema de gestão e frente de caixa (PDV) para lojas de varejo, distribuído no modelo **SaaS multi-loja**. Cada cliente (lojista) recebe uma **licença** com identificador de loja próprio, logo personalizada e credenciais de acesso, enquanto o administrador da plataforma gerencia todas as licenças em um painel master. As categorias padrão de produto (Roupa, Acessório e Brinquedo) indicam foco em lojas infantis, mas a estrutura de produto com variações de tamanho e cor atende a qualquer varejo.

1.3 Principais recursos

- **Gestão de licenças:** criação, edição, bloqueio imediato e exclusão de clientes pelo painel master.
- **Frente de caixa (PDV):** vendas com busca por nome, código ou tamanho, desconto em reais, pagamento misto e troco.
- **Estoque pai e filho:** produto (pai) com variações de tamanho, cor, código de barras e quantidade (filho), incluindo controle de peças com defeito.
- **Clientes e fiado:** cadastro, dívida (crediário) com baixa parcial ou total e saldo de crédito de troca.

- **Devolução e troca:** retorno da peça à prateleira ou ao estoque de defeitos, com estorno em dinheiro ou geração de crédito.
- **Controle de caixa:** saldo em tempo real, entradas (suprimento), sangrias e fechamento.
- **Dashboard gerencial:** faturamento, lucro bruto, ticket médio e valor imobilizado em estoque por período.
- **Alertas de estoque baixo** e lista das últimas vendas.
- **Cupom não fiscal** para impressora térmica de 80 mm, com logo e nome da loja.
- **PDV mobile** com leitura de código pela câmera do celular.
- **Atualização automática** dos dados a cada 20 segundos entre os dispositivos da mesma loja.
- **Acesso seguro:** login validado no banco, senhas com hash, sessão por token, isolamento por loja (RLS) e bloqueio de licença com efeito imediato nos dados.
- **Relatório em PDF** do período e **etiquetas com QR Code** para impressão em lote.
- **Estoque atômico:** vendas simultâneas no desktop e no celular não corrompem as quantidades.

1.4 Componentes da solução

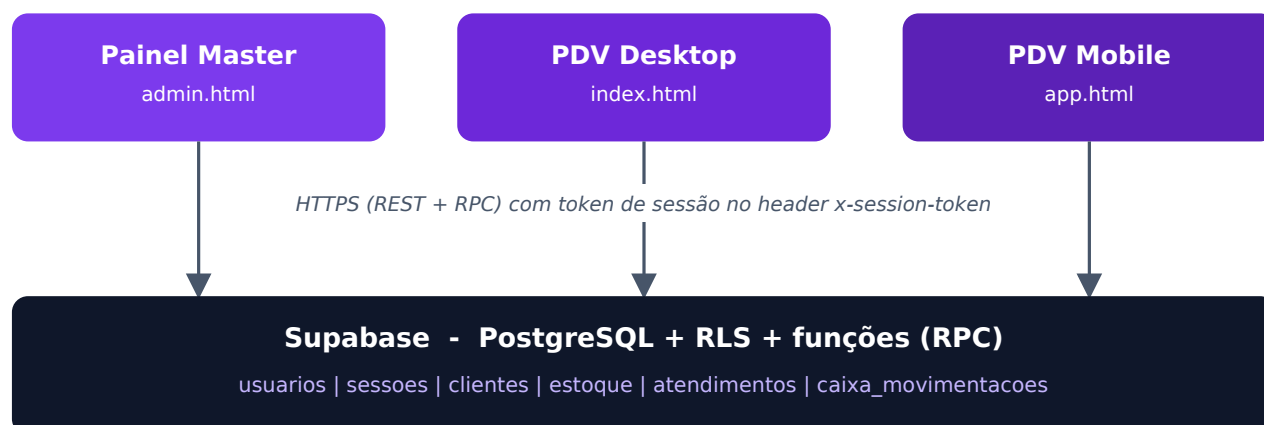
Arquivo	Módulo	Usuário	Dispositivo	Função principal
admin.html	Painel Master	Administrador da plataforma	Desktop	Gestão de licenças (criar, editar, bloquear e excluir)
index.html	KidsPro Caixa & Gestão	Lojista / operador de caixa	Desktop ou tablet	PDV completo, clientes e fiado, estoque, caixa e relatórios
app.html	KidsPro PDV Mobile	Vendedor	Celular	Venda rápida com leitor de código e consulta de estoque
kidspro_setup.sql	Script do banco	Administrador técnico	Supabase (SQL Editor)	Tabelas, hash de senhas, sessões, RLS e funções

2. Arquitetura

2.1 Visão geral

A solução é composta por três páginas HTML estáticas com JavaScript puro, sem framework e sem etapa de build, mais um script SQL que prepara o banco. Não existe servidor de aplicação próprio: as páginas conversam com o **Supabase** (PostgreSQL gerenciado com API REST) por meio da biblioteca *supabase-js* v2.

Na **versão 2.0**, o controle de acesso deixou de depender do navegador. Login, sessão, isolamento entre lojas e baixa de estoque passaram a ser executados **dentro do banco** (funções SQL e políticas RLS). O navegador continua responsável pela interface e pelos cálculos de tela (totais, troca, indicadores).



2.2 Stack tecnológica

Camada	Tecnologia	Uso no sistema
Interface	HTML5 + JavaScript (vanilla)	Três páginas independentes, sem build
Estilo	Tailwind CSS (CDN) e fonte Inter	Tema escuro com efeito glassmorphism, responsivo
Ícones	Lucide 0.383.0 (unpkg)	Versão fixada na v2.0 (antes usava @latest)
Banco de dados	Supabase / PostgreSQL + pgcrypto	Dados, hash bcrypt de senhas, funções SQL e políticas RLS
Acesso a dados	supabase-js v2 (REST + RPC)	Cliente recriado após o login com o header x-session-token
Atualização	Polling a cada 20 s	Recarrega os dados da loja no PDV desktop (substitui o Realtime da v1)
Leitor de código	html5-qrcode 2.3.8	Câmera traseira no PDV mobile (versão fixada)
PDF e QR	jsPDF 2.5.1, jspdf-autotable 3.5.25, qrcodejs 1.0.0	Relatório de vendas em PDF e etiquetas com QR Code (implementados na v2.0)
Impressão	window.open + HTML/CSS	Cupom térmico 80 mm e folha de etiquetas
Sessão local	localStorage do navegador	Token de sessão e dados básicos do usuário (sem senha)

2.3 Modelo multi-loja (multi-tenant)

O isolamento entre clientes é feito pela coluna `loja_id`, presente em todas as tabelas de negócio. Na v2.0 essa regra é **imposta pelo banco**: as políticas RLS comparam o `loja_id` de cada linha com o da sessão identificada pelo token. Mesmo que o navegador envie outro `loja_id` ou remova o filtro da consulta, o banco oculta as linhas de outras lojas e recusa gravações fora da loja da sessão. Usuários com o mesmo `loja_id` compartilham os mesmos dados, e é assim que o PDV desktop e o mobile de uma loja enxergam o mesmo estoque e o mesmo caixa.

2.4 Sessão e licenciamento

- O login chama a função `login(p_user, p_pass)`. O banco compara a senha com o hash bcrypt, exige `ativo = true`, cria uma linha em `sessoes` (token uuid válido por 12 horas) e devolve o token e os dados do usuário, **sem a senha**.
- O navegador guarda o token no `localStorage` e recria o cliente Supabase enviando o header `x-session-token` em todas as requisições.

3. No banco, a função `sessao_usuario()` converte o token no usuário ativo correspondente. As políticas RLS usam essa função.
4. Ao abrir a página e a cada **5 minutos**, o sistema chama `validar_sessao()`. Se o token expirou ou a licença foi bloqueada ou excluída, exibe um aviso e faz logout automático.
5. **Bloqueio no painel master:** a partir do bloqueio o banco deixa de entregar dados ao cliente (efeito imediato nas consultas); a tela já aberta é encerrada em até 5 minutos.
6. **Sair** chama `logout()`, que apaga o token no banco, e limpa o armazenamento local.

2.5 Chaves de armazenamento local

Chave	Módulo	Conteúdo
kidspro_token	index.html e app.html	Token de sessão do lojista/vendedor
kidspro_user	index.html e app.html	Dados básicos do usuário (id, nome, loja_id, logo_url). Não contém senha
kidspro_master_token	admin.html	Token de sessão do administrador
kidspro_master_session	admin.html	Dados básicos do administrador (sem senha)

2.6 Camada de segurança no banco

Objeto	Função
hash_senha()	Trigger que grava qualquer senha nova ou alterada como hash bcrypt. Senhas antigas em texto puro são convertidas ao rodar o script.
sessao_usuario()	Identifica o usuário ativo a partir do header x-session-token; base de todas as políticas.
login / validar_sessao / logout	Funções (RPC) chamadas pelo navegador para entrar, conferir e encerrar a sessão.
ajustar_estoque()	Baixa ou devolução de estoque de forma atômica, restrita à loja da sessão.
Política loja_iso	Em clientes, estoque, atendimentos e caixa_movimentacoes: leitura e escrita apenas para o loja_id da sessão.
Política so_admin	Na tabela usuarios: somente administradores leem ou alteram.
sessoes	RLS ativo e sem política: nenhum acesso direto, somente pelas funções acima.

3. Módulos do sistema

3.1 Painel Master (admin.html)

Área restrita ao administrador da plataforma. O login usa a função `login()` e só libera o painel se o perfil for `admin`. A cada abertura a sessão é conferida com `validar_sessao()`.

Listagem de licenças

Tabela com nome da empresa, logo (miniatura), ID da loja, login, status (Ativo/Bloqueado) e ações de editar e excluir, ordenada por nome.

Cadastro e edição de licença

Campo	Descrição	Regra
Nome/Empresa	Nome exibido no cupom impresso	Obrigatório
ID da Loja	Identificador de isolamento dos dados (ex.: loja_maria)	Obrigatório; espaços são removidos e o texto vai para minúsculas; sugere o prefixo loja_
URL da Logo	Link público da imagem da marca	Opcional; deve começar com https:// ; aparece no menu, no cabeçalho mobile e no cupom
Login	Nome de usuário de acesso	Obrigatório e único
Senha	Senha de acesso	Obrigatória ao criar. Na edição, em branco mantém a atual. Gravada como hash
Permissão	Cliente (vendedor): acessa PDV desktop e mobile. Master Admin: acessa este painel	Valores gravados: vendedor ou admin

Ações

- **Nova Licença:** cria o usuário com `ativo = true`.
- **Ativar/Bloquear:** alterna o campo `ativo`. Cliente bloqueado perde o acesso aos dados (ver seção 2.4).
- **Excluir:** remove o usuário após confirmação (as sessões dele também são removidas); o painel impede que o administrador exclua a si mesmo.
- **Sair:** encerra a sessão no banco e recarrega a página.

Dica de operação

Para que o PDV desktop e o celular de um mesmo lojista vejam os mesmos dados, ambos devem usar usuários com o **mesmo ID da Loja** (pode ser o mesmo login nos dois aparelhos ou dois usuários distintos apontando para a mesma loja).

3.2 PDV Desktop (index.html)

Aplicação principal do lojista, pensada para computador ou tablet. A tela é dividida em três áreas: **barra lateral**, **coluna de indicadores** e **área de trabalho** com quatro abas.

Barra lateral

- Logo da loja (a partir de `logo_url`, com `logo.png` como padrão).
- Menu: Frente de Caixa (PDV), Clientes & Fiado, Estoque (Pai e Filho), Dashboard & Relatórios.
- Lista das **5 últimas vendas** (data, método, cliente, valor) e botão Sair.

Coluna de indicadores

- **Saldo Caixa** com botão de ocultar valor, e atalhos **Entrada** (suprimento), **Sangria** e **Fechar Caixa**.
- **Crediário Fiado**: soma da dívida de todos os clientes.
- **Alertas de Estoque**: variações com menos de 3 unidades.

Aba Frente de Caixa (PDV)

- Lista de atendimentos (data, cliente, método, total) com botão de impressão do cupom.
- **Nova Venda**: data, cliente (padrão Consumidor Final), busca de variação por nome, código ou tamanho, quantidade, cesta de itens, desconto em reais e total. A tecla Enter adiciona o item selecionado.
- **Recebimento**: várias formas de pagamento na mesma venda (Dinheiro, PIX, Crédito, Débito e Fiado), uso do saldo de troca do cliente e indicação de valor faltante, exato ou troco. **Novo na v2.0**: o desconto e cada forma de pagamento com seu valor ficam gravados na venda.
- **Devolução / Troca**: descrita na seção 6.4.

Aba Clientes & Fiado

- Cartões de cliente com nome, telefone, dívida e saldo de troca; busca por nome.
- Cadastro e edição de cliente (nome e telefone).
- Botão **Receber** nos clientes com dívida: informa o valor pago (parcial ou total) e lança a entrada no caixa.

Aba Estoque (Pai e Subestoque)

- Tabela de produtos pai com categoria, preço de venda, total na prateleira e total de defeitos; busca por nome; editar e excluir.
- **Cadastro de produto**: nome, categoria, fornecedor/marca, custo, margem % e preço de venda (o campo alterado recalcula o outro).
- **Variações (subestoque)**: tamanho, cor, código de barras e quantidade; cada variação é uma linha vendável.

Aba Dashboard & Relatórios

- Filtro por período (padrão: do dia 1º do mês até hoje).
- Indicadores: **Faturamento**, **Lucro Bruto**, **Ticket Médio** e **Imobilizado**.
- Tabela de vendas do período (data, cliente, método, **desconto**, total). O alinhamento das colunas foi corrigido na v2.0.
- **Relatório em PDF** (novo): resumo do período (faturamento, lucro bruto, ticket médio, quantidade de vendas) e tabela de vendas, com download automático.
- **Etiquetas com QR Code** (novo): marque as variações desejadas e clique em Imprimir; abre uma folha com QR do código de barras, nome e tamanho, e chama a impressão.

Atualização dos dados

O PDV desktop recarrega os dados da loja automaticamente a cada **20 segundos**, além de recarregar após cada operação local. Assim, vendas feitas no celular aparecem no desktop em até 20 segundos. A v1.0 usava Realtime sem filtro; ele foi substituído porque o Realtime com isolamento por loja exigiria autenticação nativa do Supabase (ver melhorias, seção 12).

3.3 PDV Mobile (app.html)

Versão enxuta para celular, otimizada para toque (sem zoom) e para uso em pé no salão de vendas.

- **Login** idêntico ao desktop, com revalidação da sessão a cada 5 minutos.
- **Cabeçalho**: logo da loja, nome KidsPro e saldo atual do caixa.

- **Aba Vendas:** busca por nome ou código (até 8 resultados) e botão de **leitor de código** com a câmera traseira. Se a leitura corresponde ao código de uma variação, o item entra no carrinho. Um único resultado na busca é adicionado com Enter.
- **Carrinho:** ajuste de quantidade com + e – (respeitando o estoque disponível) e total.
- **Cobrança:** PIX (padrão), Dinheiro, Crédito ou Débito; ao confirmar, a venda é gravada e aparece a opção de imprimir o recibo.
- **Aba Balanço:** consulta de estoque por variação (produto, tamanho, quantidade e preço) com filtro e contador. **Novo na v2.0:** o leitor de código também funciona aqui e filtra a lista pelo item lido.

Diferenças em relação ao desktop

O mobile não tem desconto, fiado, crédito de troca, devolução, cadastro de produtos/clientes nem relatórios. As vendas feitas nele são registradas com o cliente "*Mobile: <nome da loja>*".

4. Modelo de dados

O esquema completo está no arquivo `kidspro_setup.sql`, que cria as tabelas que faltarem, adiciona as colunas novas, aplica as regras de segurança e não apaga dados existentes. Todas as tabelas de negócio possuem `loja_id` (texto).

4.1 Tabelas

usuarios (licenças)

Coluna	Tipo	Descrição
id	bigint (PK)	Identificador do usuário
nome	texto	Nome da empresa/vendedor (exibido no cupom)
username	texto (único)	Login de acesso
senha	texto	Hash bcrypt , gerado automaticamente pelo trigger <code>hash_senha</code>
role	texto	vendedor ou admin
loja_id	texto	Identificador da loja (minúsculo, sem espaços)
logo_url	texto	URL https da logo da loja
ativo	booleano	Licença ativa (true) ou bloqueada (false)

sessoes (nova na v2.0)

Coluna	Tipo	Descrição
token	uuid (PK)	Token enviado pelo navegador no header <code>x-session-token</code>
usuario_id	bigint (FK)	Usuário dono da sessão; removida junto com o usuário
expira	timestampz	Validade (padrão: 12 horas após o login); sessões vencidas são limpas a cada login

clientes

Coluna	Tipo	Descrição
id	bigint (PK)	Identificador do cliente
nome, tel	texto	Dados de contato
divida	numérico	Saldo devedor do fiado (crediário)
credito_loja	numérico	Saldo de crédito de troca do cliente
loja_id	texto	Loja proprietária

estoque (produto pai)

Coluna	Tipo	Descrição
id	bigint (PK)	Identificador do produto
desc_produto	texto	Nome do produto
categoria, fornecedor	texto	Roupa, Acessório ou Brinquedo; fornecedor/marca livre
custo, margem, venda	numérico	Custo, margem % e preço de venda (compartilhados por todas as variações)
variacoes	jsonb	Lista de variações (subestoque). Ver 4.2
created_at	timestamp	Usado para ordenar (mais recentes primeiro)
qtd, tamanho, cor, cod	opcionais (legado)	Se variacoes estiver vazio e qtd > 0, o sistema cria uma variação a partir destes campos

atendimentos (vendas)

Coluna	Tipo	Descrição
id	bigint (PK)	Gerado no navegador com Date.now() (timestamp em ms)
data	date	Data da venda (AAAA-MM-DD), no fuso local do usuário
cliente	texto	Nome do cliente, "Consumidor Final" ou "Mobile: nome"
itens	jsonb	Itens vendidos. Ver 4.2
total, custo_total	numérico	Total cobrado (já com desconto) e custo total dos itens
desconto	numérico	Novo. Desconto em reais aplicado na venda
pagamentos	jsonb	Novo. Formas de pagamento e valores. Ver 4.2
metodo, status	texto	Formas usadas unidas por "+" (ex.: PIX+Dinheiro), ou "Troca"/"Misto c/ Saldo"; status sempre "Concluído"
loja_id, created_at	texto, timestamp	Loja e data de criação

caixa_movimentacoes

Coluna	Tipo	Descrição
id	bigint (PK)	Identificador da movimentação
tipo	texto	venda, suprimento (entrada) ou sangria (saída); validado por constraint
valor	numérico	Valor positivo; o sinal é definido pelo tipo
descricao	texto	Ex.: "Venda #123", "Fiado", "Fechamento", "Devolução: produto (motivo)"
loja_id, created_at	texto, timestamp	Loja e data

4.2 Estruturas JSON

estoque.variacoes (um objeto por tamanho/cor):

```
[
  { "tamanho": "M", "cor": "Rosa", "cod": "7890001", "qtd": 5, "qtd_defeito": 1 },
  { "tamanho": "G", "cor": "Rosa", "cod": "7890002", "qtd": 2, "qtd_defeito": 0 }
]
```

atendimentos.itens (um objeto por linha da venda; idx_var é a posição da variação no array do produto):

```
[
  { "key": "12-0", "id": 12, "idx_var": 0, "desc": "Vestido Floral (M/Rosa)",
    "preco": 89.90, "custo": 45.00, "qtd": 2 }
]
```

atendimentos.pagamentos (venda paga com duas formas):

```
[
  { "metodo": "Dinheiro", "valor": 100.00 },
  { "metodo": "PIX", "valor": 79.80 }
]
```

Cálculo do saldo de caixa: saldo = soma(venda + suprimento) – soma(sangria) sobre todas as movimentações da loja.

4.3 Funções SQL

Função	Tipo	Descrição
hash_senha()	trigger	Gera o hash bcrypt de senhas novas ou alteradas em usuarios
sessao_usuario()	interna (security definer)	Retorna o usuário ativo do token do header; usada nas políticas RLS
login(p_user, p_pass)	RPC	Valida credenciais, cria a sessão e devolve token e dados do usuário (ou nulo)
validar_sessao()	RPC	Devolve os dados do usuário da sessão atual ou nulo se inválida/expirada/bloqueada
logout()	RPC	Apaga a sessão atual
ajustar_estoque(p_id, p_idx, p_campo, p_delta)	RPC	Soma p_delta em qtd ou qtd_defeito da variação p_idx, sem passar de zero, somente na loja da sessão. Delta negativo dá baixa

5. Regras de negócio

Cód.	Regra	Detalhe
RN01	Preço e margem	$Venda = custo + custo \times margem/100$. $Margem = (venda - custo) \div custo \times 100$. Os cálculos só ocorrem quando o custo é maior que zero.
RN02	Variações obrigatórias	Todo produto precisa de ao menos uma variação. Valores padrão: tamanho "U", cor "Padrão", quantidade 0.
RN03	Disponibilidade	Só variações com quantidade maior que zero aparecem na venda. A quantidade pedida (somada ao que já está na cesta) não pode exceder o estoque.
RN04	Total da venda	$Total = \max(0; soma(preço \times qtd) - desconto)$. O desconto em reais é gravado na coluna desconto.
RN05	Pagamento misto	Métodos: Dinheiro, PIX, Crédito, Débito e Fiado. A soma recebida deve ser igual ou maior que o total a pagar; o excedente é troco. Cada forma e valor ficam em pagamentos; o campo metodo guarda as formas unidas por "+".
RN06	Fiado	Exige cliente cadastrado (não vale para Consumidor Final). O valor lançado como Fiado é somado à dívida do cliente.
RN07	Saldo de troca	Se o cliente tem crédito, aparece a opção de usá-lo. $Valor\ usado = \min(total; crédito)$. O valor é debitado do crédito do cliente.
RN08	Entrada no caixa	Entra no caixa (tipo venda) o valor pago sem contar Fiado, menos o troco, se positivo. Fiado e saldo de troca não geram entrada.
RN09	Recebimento de fiado	Valor deve ser maior que zero e não maior que a dívida. Reduz a dívida e lança suprimento com descrição "Fiado".
RN10	Devolução	$Valor = quantidade \times preço\ atual$ do produto. A peça volta à prateleira (qtd) ou ao estoque de defeitos (qtd_defeito) via ajustar_estoque. Estorno lança sangria; crédito soma no saldo do cliente (cliente obrigatório).
RN11	Fechamento de caixa	Após confirmação, lança sangria igual ao saldo atual com descrição "Fechamento", zerando o caixa.
RN12	Estoque baixo	Alerta para variação com quantidade menor que 3 (inclusive zero).
RN13	Indicadores	$Faturamento = soma\ dos\ totais\ no\ período$. $Lucro\ bruto = faturamento - soma\ do\ custo_total$. $Ticket\ médio = faturamento \div n^o\ de\ vendas$. $Imobilizado = soma(qtd \times custo)$ de todas as variações.
RN14	Licença e sessão	Só usuários com ativo = true entram. A sessão vale 12 horas e é conferida ao abrir a página e a cada 5 minutos; se falhar, logout com aviso.
RN15	Regras do mobile	Método padrão PIX; sem desconto, fiado ou crédito. Cliente gravado como "Mobile: nome".
RN16	Identificação da venda	$id = Date.now()$ no momento da confirmação. Exibido como "Venda #id" no histórico do caixa.
RN17	Cupom	Cupom "NÃO FISCAL" em 80 mm com logo, nome da loja, data, cliente, itens e total. Textos são escapados antes de entrar no HTML.
RN18	Estoque atômico	Toda baixa por venda e todo retorno por devolução são feitos por ajustar_estoque no banco. Vendas simultâneas (desktop e mobile) não sobrepõem uma à outra e a quantidade nunca fica negativa.
RN19	Isolamento por loja	O banco só entrega e só aceita linhas do loja_id da sessão (RLS), independentemente do que o navegador enviar.
RN20	Datas locais	Datas de venda e de relatório usam o fuso do dispositivo, evitando venda tarde da noite gravada no dia seguinte.
RN21	Senhas	Gravadas apenas como hash. Na edição de licença, senha em branco mantém a atual.

Cód.	Regra	Detalhe
RN22	Logo	A URL da logo deve ser https. Textos digitados (produto, cliente, empresa) são escapados ao exibir.

6. Fluxos operacionais

6.1 Login e validação de licença

1. Usuário informa login e senha.
2. O navegador chama a função `login()` no banco, que confere a senha (hash) e o campo ativo.
3. Em caso de sucesso, o token é guardado localmente, o cliente é recriado com o header `x-session-token`, a logo é aplicada e o temporizador de 5 minutos é iniciado (no desktop, também a atualização de 20 s).
4. Carrega clientes, estoque, vendas e movimentações da loja e abre a aba inicial.
5. Se falhar, exibe "Usuário, senha incorretos ou bloqueado".

6.2 Venda no PDV desktop

1. Clicar em **Nova Venda**; conferir data e escolher o cliente.
2. Buscar a variação, informar a quantidade e adicionar à cesta (repetir para outros itens).
3. Informar desconto, se houver; conferir o total.
4. Clicar em **Ir para Pagamento**; marcar o uso do saldo de troca (se disponível).
5. Definir as formas de pagamento e valores; o painel mostra Falta Pagar, Exato ou Troco.
6. Confirmar. O sistema grava a venda, lança o caixa, ajusta dívida e crédito do cliente, baixa o estoque e recarrega os dados.
7. Na tela **Concluído!**, imprimir o cupom ou finalizar.

6.3 Venda no PDV mobile

1. Buscar o produto pelo nome/código ou tocar no ícone de leitor e apontar a câmera para o código.
2. Ajustar quantidades no carrinho e tocar em **Cobrar**.
3. Selecionar PIX, Dinheiro, Crédito ou Débito e tocar em **Confirmar**.
4. O sistema grava a venda, lança o caixa, baixa o estoque e oferece Imprimir ou Finalizar.

6.4 Devolução ou troca

1. Em **Frente de Caixa**, clicar em Devolução / Troca.
2. Buscar e selecionar a peça devolvida e informar a quantidade.
3. Escolher o destino: *Voltar p/ Prateleira* ou *Marcar como Defeito*.
4. Escolher a ação financeira: *Estorno* (retira dinheiro do caixa) ou *Crédito de Troca* (exige selecionar o cliente).
5. Confirmar. O estoque, o caixa ou o crédito do cliente são atualizados.

6.5 Recebimento de fiado

1. Aba **Clientes**, cartão do cliente, botão **Receber**.
2. Informar o valor (até o total da dívida) e confirmar.
3. A dívida é reduzida e o valor entra no caixa como suprimento.

6.6 Cadastro de produto

1. Aba **Estoque**, botão **+ Cadastrar Produto**.
2. Preencher nome, categoria, fornecedor, custo e margem (ou preço de venda).
3. Adicionar uma ou mais variações (tamanho, cor, código, quantidade) com o botão **+**.
4. Salvar Produto.

7. Guias rápidos por perfil

7.1 Administrador da plataforma

Tarefa	Como fazer
Acessar	Abrir admin.html, informar usuário e senha de administrador e clicar em Entrar no Painel.
Criar cliente	Nova Licença, preencher Nome, ID da Loja (ex.: loja_maria), Logo, Login, Senha, Permissão Cliente e Salvar Dados.
Trocar logo ou senha	Ícone de lápis na linha do cliente, alterar o campo e Salvar Dados. Senha em branco mantém a atual; a logo deve ser um link https.
Bloquear por inadimplência	Clicar no selo Ativo ; ele muda para Bloqueado . O banco deixa de entregar dados na hora e o PDV aberto é encerrado em até 5 minutos.
Reativar	Clicar no selo Bloqueado .
Excluir cliente	Ícone de lixeira e confirmar. Remove o login; os dados da loja permanecem nas tabelas (o vínculo é o loja_id).

7.2 Lojista / operador de caixa (desktop)

Tarefa	Como fazer
Lançar entrada ou sangria	Painel Saldo Caixa, botão Entrada ou Sangria, informar valor e motivo, OK.
Fechar o caixa	Botão Fechar Caixa e confirmar. O saldo é zerado por uma sangria.
Ocultar saldos	Ícone de olho no cartão Saldo Caixa.
Reimprimir cupom	Ícone de impressora na linha da venda em Frente de Caixa.
Cadastrar cliente	Aba Clientes, + Novo Cliente.
Consultar lucro do mês	Aba Dashboard & Relatórios; ajustar Início e Fim.
Ver produtos acabando	Cartão Alertas Estoque (menos de 3 unidades).
Baixar relatório em PDF	Aba Dashboard & Relatórios, escolher o período e clicar em PDF.
Imprimir etiquetas	Aba Dashboard & Relatórios, marcar as variações na lista de etiquetas e clicar em Imprimir.

7.3 Vendedor (mobile)

Tarefa	Como fazer
Instalar atalho	Abrir app.html no navegador do celular e usar Adicionar à tela inicial.
Vender com leitor	Aba Vendas, ícone de QR, permitir a câmera e apontar para o código da etiqueta.
Consultar estoque	Aba Balanço, digitar nome ou código no filtro, ou tocar no ícone de QR e ler a etiqueta.
Sair	Ícone de saída no topo direito.

8. Guia de implantação

8.1 Pré-requisitos

- Projeto no Supabase (URL e chave pública *anon*).
- Hospedagem estática com HTTPS (Netlify, Vercel, GitHub Pages, Cloudflare Pages ou servidor próprio). O HTTPS é obrigatório para a câmera do leitor funcionar.
- Arquivo *logo.png* opcional na mesma pasta (logo padrão quando a loja não tem URL própria).

8.2 Instalação nova

1. Criar o projeto no Supabase.
2. Abrir o *SQL Editor*, colar todo o conteúdo de *kidspro_setup.sql* e executar.
3. Nos três arquivos HTML, conferir as constantes *SUPABASE_URL* e *SUPABASE_KEY* (chave *anon*, mesmo valor nos três). **Nunca use a chave *service_role* no navegador.**
4. Publicar *index.html*, *app.html* e *admin.html*. Sugere-se manter o admin em um endereço não divulgado.
5. Entrar no admin com *admin / TROQUE-ESTA-SENHA* e **trocar a senha imediatamente** (lápiz na linha do usuário, informar a nova senha).
6. Criar a primeira licença de cliente e testar o login no PDV.
7. Cadastrar produtos com variações e fazer uma venda de teste no desktop e outra no mobile.

8.3 Atualização a partir da versão 1.0

1. **Primeiro** execute *kidspro_setup.sql*. Ele não apaga dados, converte as senhas existentes em hash e cria as colunas e funções novas.
2. **Depois** publique os três HTML novos. Publicar os HTML antes do SQL impede o login, porque eles chamam funções que ainda não existiriam.
3. Os usuários precisarão entrar novamente uma vez (a sessão antiga do navegador não tem token).
4. Os logins e senhas atuais continuam valendo. Vendas antigas ficam com desconto 0 e sem detalhamento de pagamentos.
5. Conferir que ninguém mais depende do aviso "Sincronizado!": agora a atualização é automática a cada 20 segundos.

8.4 O que o script SQL faz

Bloco	Ação
Tabelas	Cria as tabelas que não existirem, incluindo sessoes, e adiciona desconto e pagamentos em atendimentos. Índices por <i>loja_id</i> .
Senhas	Ativa a extensão <i>pgcrypto</i> , cria o trigger de hash e converte as senhas existentes.
Sessão	Cria <i>sessao_usuario</i> , <i>login</i> , <i>validar_sessao</i> e <i>logout</i> .
Estoque	Cria <i>ajustar_estoque</i> (baixa e devolução atômicas).
RLS	Ativa RLS nas seis tabelas e cria as políticas <i>loja_iso</i> e <i>so_admin</i> .
Permissões	Libera execução das quatro funções públicas para o navegador.
Administrador	Cria o usuário admin inicial somente se não existir nenhum administrador.

8.5 Checklist de validação pós-implantação

Teste	Resultado esperado
Consulta sem token (ver 9.3)	Retorna lista vazia []
Login com senha errada	Mensagem de acesso negado
Login de cliente em admin.html	Acesso negado (perfil não é admin)
Duas lojas com usuários diferentes	Cada uma vê apenas o próprio estoque, clientes e vendas
Bloquear cliente no admin	Consultas passam a retornar vazio e o PDV desloga em até 5 minutos
Venda no mobile e no desktop ao mesmo tempo	Estoque final correto (soma das duas baixas)
Botão PDF e Imprimir Etiquetas	Baixa o PDF e abre a folha de etiquetas
Venda depois das 21h	Data da venda é a do dia local

9. Segurança

A versão 2.0 tratou os pontos críticos da análise anterior. Esta seção descreve o que está implementado, o que ainda merece atenção e como verificar.

9.1 Controles implementados

Controle	Como funciona
Senhas com hash	bcrypt via pgcrypto; trigger converte qualquer senha gravada. O navegador nunca recebe nem guarda a senha.
Login no servidor	A função login compara a senha no banco e só então emite o token de sessão.
Sessão com validade	Token uuid aleatório, validade de 12 horas, revalidado a cada 5 minutos; logout apaga o token.
Isolamento por loja (RLS)	Todas as tabelas de negócio só aceitam e só entregam linhas do loja_id da sessão.
Perfil administrador no banco	A tabela usuarios só é acessível a quem tem perfil admin na sessão; a checagem não depende da tela.
Licença bloqueada	sessao_usuario exige ativo = true, então o bloqueio corta o acesso aos dados imediatamente.
Estoque atômico	ajustar_estoque atualiza dentro do banco, restrito à loja da sessão.
Proteção contra XSS	Textos digitados são escapados ao entrar em HTML; logo aceita apenas https.
Dependências	Lucide e html5-qrcode com versão fixada.

9.2 Pontos que ainda merecem atenção

Nº	Ponto de atenção	Grau	Recomendação
1	Não há limite de tentativas de login; a função login pode ser chamada repetidamente (força bruta).	Média	Registrar tentativas por usuário/IP e bloquear temporariamente; ativar proteção de taxa do Supabase ou CAPTCHA.
2	Os totais, o caixa, a dívida e o crédito são calculados no navegador e enviados ao banco. Um usuário mal-intencionado da própria loja poderia gravar valores incorretos.	Média	Mover a finalização da venda para uma função transacional que recalcule os valores no servidor.
3	Uma licença corresponde a um login compartilhado pela loja; não há rastreo de quem operou.	Média	Cadastrar operadores por loja com perfis e auditoria.
4	O token fica no localStorage; uma falha de XSS futura poderia expô-lo.	Baixa	Manter o uso de esc() em todo texto novo; adicionar Content-Security-Policy na hospedagem.
5	O administrador consulta usuarios com select *, o que traz o hash das senhas para a tela.	Baixa	Expor uma view sem a coluna senha para o painel.
6	Tailwind CSS carrega por CDN sem versão fixa e sem SRI.	Baixa	Empacotar o CSS ou fixar versão com verificação de integridade.
7	A chave anon aparece no código-fonte. Isso é esperado no Supabase, e a proteção é feita pelas políticas RLS.	Info	Nunca colocar a chave service_role nos arquivos; rodar o teste da seção 9.3 após qualquer alteração de políticas.

9.3 Como verificar o isolamento

Este teste confirma que a chave pública, sem token de sessão, não enxerga dados. Substitua os valores pelos do seu projeto:

```
curl "SUA_URL/rest/v1/estoque?select=*" \  
  -H "apikey: SUA_CHAVE_ANON" \  
  -H "Authorization: Bearer SUA_CHAVE_ANON"  
  
# Resultado esperado: [] (lista vazia)  
# Repita para: clientes, atendimentos,  
# caixa_movimentacoes, usuarios e sessoes
```

10. Histórico de alterações (v1.0 para v2.0)

Área	Na v1.0	Na v2.0
Login	Consulta usuario e senha direto na tabela, no navegador	Função login no banco, com token de sessão
Senhas	Texto puro; a senha ficava salva no navegador	Hash bcrypt; o navegador não recebe a senha
Isolamento entre lojas	Filtro loja_id aplicado pela tela	RLS no banco por sessão
Acesso ao painel admin	Perfil conferido na tela	Perfil conferido no banco (política so_admin)
Edição de licença	Senha sempre reenviada	Senha em branco mantém a atual; logo exige https
Baixa de estoque	Tela regravava todo o JSON de variações	Função atômica ajustar_estoque
Desconto e pagamentos	Não gravados	Colunas desconto e pagamentos; método composto (PIX+Dinheiro)
Relatório em PDF	Botão sem função	Implementado com resumo e tabela
Etiquetas	Botão sem função	Folha de etiquetas com QR Code
Tabela de vendas do relatório	Cabeçalho com 5 colunas e linhas com 4	Coluna de desconto alinhada
Datas	UTC (venda após 21h caía no dia seguinte)	Fuso local do dispositivo
Texto em HTML	Inserido sem escape	Escapado (esc)
Sincronização	Realtime em todo o schema, sem filtro por loja	Atualização automática a cada 20 s
Balanço mobile	Leitor abria a câmera sem efeito	Leitor filtra a lista pelo código lido
Bibliotecas	lucide@latest e html5-qrcode sem versão	Versões fixadas

11. Limitações conhecidas

Itens que continuam na versão 2.0. Nenhum impede a operação básica de venda.

Nº	Situação	Impacto
1	Venda, caixa, fiado, crédito e estoque são gravados em chamadas separadas. O estoque é atômico, mas o conjunto não é uma única transação; uma falha de rede no meio pode deixar a venda gravada sem a entrada no caixa.	Rara inconsistência entre venda e caixa.
2	A devolução não se vincula à venda original, usa o preço atual do produto e não altera a venda. Não há cancelamento de venda (status é sempre Concluído).	Diferenças possíveis quando o preço mudou.
3	O caixa não tem abertura, turno ou operador; Fechar Caixa apenas lança uma sangria do saldo.	Sem conferência do valor contado.
4	Os pagamentos por forma já são gravados, mas o dashboard ainda não tem relatório de faturamento por forma de pagamento.	Dado disponível, tela pendente.
5	O Balanço mobile é somente consulta: não há contagem nem ajuste de estoque.	Sem inventário pelo celular.
6	Defeitos aparecem no desktop apenas como total por produto, e não são vendáveis.	Sem detalhe por variação.
7	A atualização é por polling (20 s) e recarrega todos os dados da loja a cada ciclo.	Atraso de até 20 s; em lojas muito grandes, considerar paginação.
8	As etiquetas usam QR Code do código cadastrado, não código de barras linear, e a impressão usa o diálogo do navegador.	Leitores de código de barras comuns podem não ler QR.

12. Melhorias recomendadas

Prioridade alta

- Limitar tentativas de login por usuário e por IP.
- Criar função transacional para finalizar a venda (venda, caixa, fiado, crédito e estoque) recalculando os valores no servidor.
- Trocar o select * do painel por uma view sem a coluna de senha.

Prioridade média

- Cadastro de múltiplos operadores por loja, com perfis (caixa, gerente) e trilha de auditoria.
- Cancelamento de venda e devolução vinculada à venda original.
- Relatório de faturamento por forma de pagamento (os dados já são gravados).
- Inventário por leitura de código no Balanço mobile.
- Abertura e fechamento de caixa com conferência de valores.

Prioridade baixa

- Migrar para Supabase Auth para voltar a usar Realtime com filtro por loja.
- Empacotar dependências (Tailwind, Lucide), habilitar PWA no mobile e Content-Security-Policy.
- Etiquetas com código de barras linear e exportação de relatórios para planilha.

13. Referência de funções

13.1 Funções JavaScript

Função	Arquivo	Descrição
criarCliente	todos	Cria o cliente Supabase com o header x-session-token lido do localStorage
esc / hoje	todos	Escapa texto para HTML / devolve a data local AAAA-MM-DD
fazerLogin / sair	index, app	Chama login e logout no banco e inicia ou encerra a sessão
validarSessaoNuvem	index, app	Chama validar_sessao e atualiza os dados locais do usuário
iniciarApp	index, app	Aplica logo, liga o temporizador de 5 min e (desktop) a atualização de 20 s; carrega dados
carregarBancoSupabase	index, app	Busca clientes, estoque, vendas e caixa da loja e calcula o saldo
obterListaVariaveis	index, app	Lista de variações vendáveis achatada a partir dos produtos
adicionarItemAoOrc / adicionarAoCarrinho	index / app	Adiciona item validando o estoque disponível
calcularTotalOrc	index	Subtotal menos desconto, com piso em zero
abrirFinalizacao / calcularTotaisPagamento	index	Prepara o recebimento e mostra falta, exato ou troco
confirmarFinalizacao	index	Grava venda (com desconto e pagamentos), caixa, fiado, crédito e baixa de estoque
confirmarVenda	app	Grava venda mobile, caixa e baixa de estoque
confirmarDevolucao	index	Devolve peça ao estoque ou defeito e estorna ou gera crédito
confirmarMovimentacaoCaixa / fecharCaixa	index	Entrada, sangria e fechamento de caixa
salvarCliente / confirmarPagamentoDivida	index	Cadastro de cliente e baixa de fiado
salvarPeca / excluirPeca	index	Cria, altera ou remove produto com variações
calcularVenda / calcularMargem	index	Conversão entre margem % e preço de venda
gerarRelatorio	index	Calcula indicadores e monta a tabela de vendas do período
gerarRelatorioPDF	index	Gera e baixa o PDF do período (novo)
imprimirEtiquetasLote	index	Monta e imprime a folha de etiquetas com QR (novo)
atualizarInterface	index	Redesenha indicadores, alertas, listas de clientes, estoque e vendas
imprimirTermica	index, app	Abre janela com cupom de 80 mm
abrirScanner / processarLeitura	app	Liga a câmera e trata o código lido (Vendas e Balanço)
loginMaster / sairMaster	admin	Login e logout do administrador

Função	Arquivo	Descrição
carregarUsuarios / salvarUsuario	admin	Lista e grava licenças (senha em branco mantém a atual)
toggleStatus / excluirUsuario	admin	Bloqueia, ativa ou exclui licença

13.2 Funções SQL

Descritas na seção 4.3: hash_senha, sessao_usuario, login, validar_sessao, logout e ajustar_estoque.

14. Glossário

Termo	Significado
PDV	Ponto de Venda; a tela onde a venda é registrada
Licença	Acesso de uma loja ao sistema, controlado por um registro em usuarios
loja_id	Identificador que separa os dados de cada loja
Produto pai / variação	Produto com preço único (pai) e suas versões por tamanho, cor e código (filho)
Fiado / crediário	Venda a prazo, com dívida registrada no cliente
Saldo de troca	Crédito na loja gerado por devolução, usável em compras futuras
Suprimento	Entrada manual de dinheiro no caixa
Sangria	Retirada de dinheiro do caixa
Ticket médio	Faturamento dividido pelo número de vendas
Imobilizado	Valor do estoque de prateleira a preço de custo
RLS	Row Level Security; regras do PostgreSQL que limitam quais linhas cada sessão acessa
RPC	Chamada de uma função do banco pelo navegador (ex.: login)
Token de sessão	Código aleatório que identifica um login válido; enviado no header x-session-token
Hash (bcrypt)	Transformação irreversível da senha; o banco guarda só o hash
Polling	Consulta repetida em intervalo fixo (aqui, a cada 20 segundos)
XSS	Ataque em que texto malicioso digitado vira código na página; evitado com escape